

ISO27001_AnnexA_Mapping

Risk ID	Risk Description	ISO 27001:2022 Control	Control Theme	Justification
GR-001	Ransomware / Unauthorized Access – No MFA on admin accounts	A.8.5 – Secure Authentication (Technological)	Technological	Implementing MFA for all administrative access directly addresses the vulnerability of credential theft. This control ensures that a compromised password alone is insufficient for system access.
GR-002	Insider Threat – Manual offboarding delays	A.5.16 – Identity Management (Organisational)	Organisational	Automating the offboarding process ensures that access rights are revoked promptly when an employee leaves, directly mitigating the risk of a disgruntled ex-employee retaining system access.
GR-003	Business Interruption – No tested offsite backups	A.8.13 – Information Backup (Technological)	Technological	This control requires organizations to back up information at intervals aligned to business needs, with protection, testing, and documentation sufficient to restore operations reliably. Implementing immutable cloud backups (e.g., AWS S3 Object Lock) directly addresses ransomware resilience.
GR-004	Phishing / BEC – No security awareness training	A.6.3 – Information Security Awareness, Education, and Training (People)	People	This control requires organizations to ensure that all employees receive ongoing information security awareness training. A simulated phishing campaign and training module directly reduce the likelihood of employees falling for social engineering attacks.
GR-005	GDPR Compliance – No Privacy Policy, Cookie Banner, or Erasure process	A.5.24 – Information Security Incident Management Planning and Preparation (Organisational) AND A.8.10 – Information Deletion (Technological)	Organisational & Technological	While GDPR is not explicitly an ISO 27001 control, implementing an incident management plan (A.5.24) ensures a structured response to data subject requests (like Right to Erasure). Additionally, A.8.10 (Information Deletion) provides the technical mechanism to permanently remove customer data upon request, addressing the GDPR gap. <i>(Note: For a more direct privacy control, some organizations also reference A.18.1.4 – Privacy and Protection of PII, though this is more common in the 2013 version)</i>